

1.

考试科目代码及名称: _____

题号	分数	阅卷人
一		
二		
三		
四		
五		
六		
七		
八		
九		
十		
十一		
十二		
十三		
十四		
十五		
总分		

注 意 事 项

1. 考生编号、姓名、报考专业须填在装订线内指定位置。
2. 所有答案须写在答题纸上，做在试题纸或草稿纸上的一律无效。
3. 答题时须写清楚题号。
4. 字迹要清楚，保持卷面清洁，一律使用黑色或蓝色字迹的钢笔或签字笔（同一科目答题的字迹须是一种颜色）。
5. 考生答完试题后，在“共 页”处填写答卷的总共页数（包括第 页）。
6. 全国统考，全国联考科目不得使用此答题纸，否则，答题结果一律无效。
7. 禁止做任何与考试无关的标记。

装订线

传输层协议 ARN SR 使用 socket 实现 CSMA/CA 降低 Latency/minor

* ARN 自动重传请求 使用 确认、超时重传机制，包括 停等、GBN、SR

1. 停等 (单帧滑动窗口)

发送方每次只允许发送一个帧，接收方每接收一个帧都要反馈一个应答信号
等待发送方收到 ACK 后才可发送下一个帧

2. GBN (多帧滑动窗口) ~~✗~~ 流水线: 未收到 ACK 可发送下一个帧

当接收方收到帧出现差错时，接收方窗口会停在这个序号并丢弃该帧之后
所有帧，发送方超时时计时器超时则重发出错的帧及其后所有帧。

GBN 为降低 ACK 开销，允许接收方 累积确认，反对最后一个连续正确帧确认
窗口尺寸为 N ，最多允许 N 个帧未确认但发送

3. SR (多帧滑动窗口) ~~✗~~

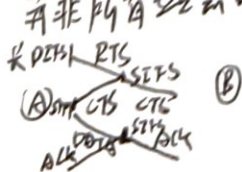
由于让发送方重传出错帧，不可允许累积确认，对所正确接收的帧
逐一确认，对出错帧发送否定帧 NAK，要求发送方立即重传 NAK 指定
帧。接收方设置帧缓冲区分以暂存失序而正确到达且序号落在接收窗
口内的帧，发送方每个 帧缓冲区 对应一个计时器，超时则重传。

4. 窗口尺寸非 $W_R + W_T \leq 2$ 后果

若一个或多个 ACK 帧丢失，则发送方会超时重传先前帧，而接收方期望收到新
帧，但新序号和旧序号重叠无法分辨。

5. CSMA/CA

无线局域网信号接收强度与发送强度，变化大，冲突检测硬件开销大
并非所有站点都会听见对方，存在 隐蔽站 问题



CTS ① 信源站发送 RTS
② 指示其他站预留期不发送

6 Socket 编程 ~~★~~ 年年年年

raw socket 原始套接字, 要有 root 权限, 允许直接访问 IP 包头

int socket 创建 socket 文件描述符,

int bind 绑定端口号, 服务端需分配端口, 不指定(0)则自动分配端口

int listen(int socket, int backlog) 开始监听 socket, 有 backlog (最多) 句处于等待连接状态

int accept 接受客户端连接请求, 三次握手成功返回

int connect 请求服务端连接, TCP 必须; UDP 也行但实际不会发送连接请求, 定 Port

参数:

INADDR_ANY 任意地址

AF_INET / PF_INET 指 IPv4 协议族

SOCKET_STREAM 流, TCP

SOCKET_DGRAM 报, UDP

发/收发:

send: UDP (调用 connect 的 UDP) 或 TCP

sendto: UDP 专用 定 Port

recv: TCP, UDP (调用 connect 的 UDP)

recvfrom: UDP 专用

read(): TCP 专用

write(): TCP 专用

close(): UDP 无状态, TCP 中发送 FIN (主动) 和 ACK FIN (被动)

connected UDP vs. unconnected UDP

UDP 无连接, 默认为 unconnected UDP 之后用 sendto 每次指定 IP 和端口, 方便的应用有发送
而 connected UDP 跟 socket 是为指定目标发送数据, 在对目标发送数据时开辟缓冲

7 Libcap/wincap 编程 ~~隔年,今年轮到了!~~

`pcap_lookupdev()` 查找可用网卡

`pcap_lookupnet()` 获得网卡参数

`pcap_open_live()` 打开网卡, `snapshot` 捕获最大字节, `promisc` 混杂

`pcap_compile()` 编译过滤策略, 把字符串编译为程序

`pcap_setfilter()` 指定过滤程序, 将编译好的程序设置给网卡

`pcap_open_offline()` 打开本地存储文件读取

`pcap_dump_open()` 打开本地存储文件写入

`pcap_dump()` 写入数据并输出到上面打开的文件中

`pcap_datalink()` 返回数据链路层类型 (Ethernet/802.11...)

处理:

`pcap_dispatch()`

处理 `cnt` 个包; `cnt=0` 时处理所有数据; `cnt=1` 时仅处理

缓冲区内的包; 出现错误、EOF、超时等时停止。

`pcap_loop()`

连续处理 ~~数据包~~ `cnt` 个包后退出; `cnt<0` 则一直循环直至

出错。

`pcap_next()`

获取下一个数据包后立即返回, 并把数据存在返回后指向的内存中

防火墙, IDS, SSL, Ipsec, SET

1. 防火墙 vs. IDS

防火墙部署于内外网之间, 控制内外数据流, 确保只有符合安全策略的数据通过
属静态防范; IDS 监视网络传输, 发现可疑行为时记录并报警、响应,
是防火墙的补充, 属动态防范。
检测异常流量数据

缺陷

防火墙无法检查不经防火墙的流量 (如内部拨号)

无法防范内部人员的攻击和威胁 (而 IDS 可以发现内部用户越权行为)

无法阻止木马病毒进入

无法发现数据驱动的攻击 (如病毒)

补充作用: IDS 可以发现内部越权行为, 防火墙不完善条件下攻击者可穿越防火墙 IDS 可发现并告警; HIDS 可以理解攻击数据, IDS 可发现网络扫描等防火墙放行攻击包, 并提供更完整的审计信息

2. 静态 vs. 动态包过滤防火墙

静态: 根据已定义的规则审查每个数据包, 与规则匹配。

动态: 会话跟踪, 动态配置包过滤规则, 审核合法用户访问外网的请求, 动态修改 ACL 规则; 当收到访问结束或超时自动删除规则。

优点: 处理性, 对网络影响小, 透明; 缺点: 依赖 IP Port, TCP/IP 信息, 且易伪造 (IP 欺骗)

3. 应用代理网关防火墙

位于应用层, 基于代理技术, 对于进入流出数据包还须审查并封装后再发

优势: 可以记录所有通信, 所有通信都从代理软件转发, 可防止数据驱动的攻击

缺点: 要理解各种应用层协议, 可能成为网络性能瓶颈, 管理复杂

4. HIDS vs. NIDS

HIDS 基于主机

优: 不用专门的硬件平台, 准确率高

能感知主机用户的攻击或误用

对网络流量大小不敏感, 能理解加密数据

缺: 系统兼容性问题, 可移植性差

维护复杂, 难以发现针对网

络的攻击

注: 主机日志 入侵安全审计系统运行数据: SNMP信息 网络故障类型 防火墙日志 交换机日志

NIDS 基于网络

优: 对用户透明, 安装方便, 不易被攻击

与操作系统无关, 可移植性好, 攻击

者不易转移证据

缺: 无法发现内部用户的误用行为

无法理解加密数据

主机在流量大的时候负荷大, 易被DOS

5. 基于异常 vs 基于误用 25分

异常

原理: 根据^{特征}特征(活动轮廓)在正常状态下的情况, 和当前的偏差大小来决定是否遭受入侵(大于阈值则异常)

优: 误报率低, 能发现未知攻击, 不用维护入侵特征库

缺: 误报率高, 不能报告准确攻击类型, 确定阈值困难

eg: 统计分析 神经网络 聚类分析
kNN Denning 入侵检测系统

误用

原理: 事先定义攻击特征, 根据与数据集中已知攻击的入侵特征对比匹配判断

优: 准确率高 误报率低, 能准确报告攻击类型

缺: 误报率高, 维护特征库抽象知识困难, 只能识别已知攻击

eg: 模式匹配 专家系统 有限Petri网 状态转移

6. IKE 两阶段

- ① IKE SA建立 主提议: (1) 策略协商 (2) 密钥交换 (3) 认证交换 6条消息
 应答提议: (1) 策略协商 (2) 密钥交换 (3) 验证协商 3条消息
- ② IPsec SA建立 快速模式: (1) 策略协商 (2) 密钥协商 (3) 认证协商 3条消息

7. 安全策略 SA + SPD + SAD 应用流程

- ① 根据 SPD 中的策略应用 IPsec 加密数据流
- ② 建立 ~~IPsec~~ IKE SA 协商/主提议
- ③ 建立 IPsec SA 快速模式
- ④ 数据发送 根据 SPD 记录对 SAD 的指针从 SAD 获得策略应用 ESP/AH
- ⑤ 接收时/删除策略 信号传输

8. IPsec 抗重放机制

序号计数器 + 抗重放窗口

每个 IPsec 包都有一个递增的序号, 新序号为 0, 到 $2^{32}-1$ 时 SA 停止重建

接收端收到窗口左侧的包则认为重放, 丢弃; 在窗口内则接收并记录需 MAC 认证; 在右侧通过 MAC 验证则记录并在窗口右

9. SSL 三协议, 握手

SSL 记录协议 (应用层传输层之间): 分段在应用层 MAC 加密 加密头

SSL 握手协议: ① 建立连接能力 (协商) ② 服务器认证 (证书) ③ 客户端认证 (证书) ④ 结束

SSL 记录协议规范协议: 通过对方将已接收的 (或新协商) 的状态复制到当前状态中, 更新密钥规范

SSL 报警协议: 使对方报警信息给对方

10. 包加密

发送: 用对方公钥加密 临时密钥, 临时密钥加密数据, 把数据和加密的临时密钥一起发送

接收: 用私钥解密 临时密钥, 临时密钥解密数据

11. DS

服务器 → 商家

发送 OI 和 PI 生成 OI MD PI MD, 金在一起生成 P O M D, 私钥加密后为 DS

商家 → 银行

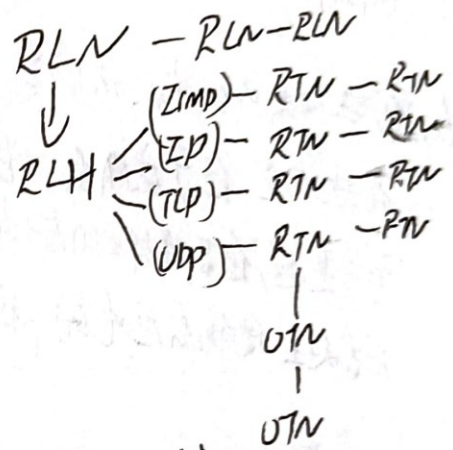
发送 $E_{K_s}[PI || DS || PI MD]$ 银行也对比 P O M D 和 p o m d

IPS Snort Iptable/netfilter

1. Snort

Snort启动时会建立三维链表，当数据包到达检测引擎时从左到右遍历三维链表进行匹配，根据当前协议选择RLH指向规则头链表指针，进入寻找RTN，匹配的则RTN后匹配OTN，RTN和OTN分别指向规则头和规则选项。若数据包与某个OTN匹配则判断为攻击数据包。

Snort交互科动作选项分为五个RLN
RLN指向一个包含四个规则头链表RLH
RLH指向RTN链表
RTN指向OTN链表



2. Iptable/Netfilter

层: Iptable (内核) Netfilter (内核层)

Netfilter在网络处理流程的若干位置放置钩子函数，可注册钩子函数，系统根据这些钩子函数优先级形成的钩子函数指针链，当数据包到达时依次交给指针链上的函数处理。

Iptable负责管理包过滤表，自上而下顺序匹配，每个钩子函数对应一个表并执行检查处理，如果有0则每个规则，包与每个匹配条件和目标动作

3. ESP/AH

ESP完整性认证包括IP包的内部部分AH为完整性认证包括整个IP报文因此隧道模式的ESP可穿透NAT，由于NAT要在将私有IP变为公用IP时修改TCP/UDP报头和，~~而隧道模式的ESP~~修改的TCP/UDP报头同步修改IP报头内部部分的报头和导致无法通过认证，而AH由于修改了IP报头而无法通过认证。

4. DMZ 作用, 屏蔽子网

解决安装防火墙后外部网络无法访问内部服务的问题

内外网均可访问 DMZ, 但禁止穿越, 中间用堡垒主机转发数据, 外部包过防火墙和内部堡垒主机均被控制时仍无法穿过内部包过防火墙攻击内网

5. VPN 工作原理

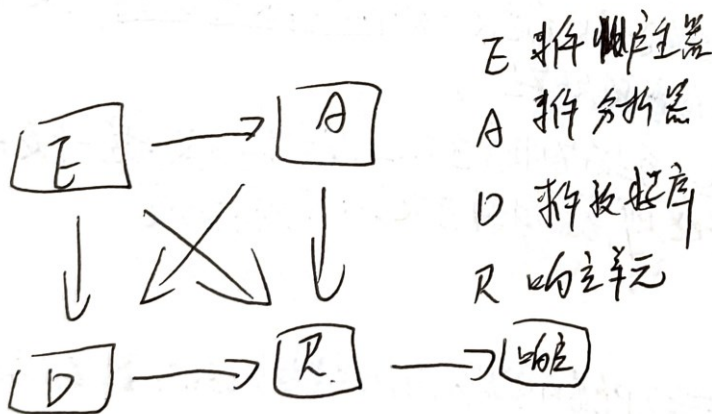
通过隧道技术用一种协议对另一种协议传输数据报文的封装传输
解封; Intranet 分支机构 Access 远端用户 extranet 合作伙伴

6. 代理网关 vs. 电路级网关

代理网关 位于应用层 电路级网关 位于传输层

前者更复杂, 但要理解应用层协议, 基于代理技术, 需要对传入传出数据解封并重新封装
后者建立传输层虚电路 通过内外网间的传输层数据, 不关心应用层数据

7. CIDF 模型



E 接收事件数据, 传给 A 和 D; A 是分析控制该用技术; D 存储 A 的数据; R 从 A 和 D 中抽取数据并启动适当响应, 通信使用 GIDD 通用入侵检测协议和 LISA 通用入侵规范语言

ARP 网络层 RIP BGP OSPF LSDBF IP 报文

- OSPF 链路状态路由选择算法 (LS) ^{链路状态路由选择算法 (Dijkstra)} 2425 考 3
OSPF 以分布式链路状态算法, 仅当变化时 (RIP 定时发送路由表) OSPF 洪泛 (而非向邻居) 而向整个 AS
发送对本链路相邻的链路状态 (而非整个路由表)
所有路由器建立一个链路状态数据库, 每个路由用 Dijkstra 算法计算自己达
到目的网络的最优路径构造路由表, 变化链路状态时每个路由重新计算
到达各自目的网络的最优路径构造新路由表
优点: 适用于大型网络, 只发送与自身相邻的路由的链路状态改变时才洪泛
且无需多次交换才能收敛, 报文大小和整个网络规模成正比
OSPF 支持对大规模 AS 分层, OSPF 报文支持认证 (防黑客入侵)

2. RIP 距离向量路由选择算法 (DV) 26 考 10 题 解决冗余设计: 毒性逆转、水平分割、最大跳数

DV 算法的基础是 Bellman-Ford (BF) 算法

	DV _x	DV _y	DV _z		DV _x	DV _y	DV _z		DV _x	DV _y	DV _z	(eg. 16 考 10 题)
初始	0	2	7	更新 1	0	2	3	更新 2	0	2	3	更新并收敛
	0	0	1		0	0	1		0	0	1	收敛
	2	0	1		2	0	1		2	0	1	
	2	1	0		2	1	0		2	1	0	

(用各结点间尚未交换过的直连链路)

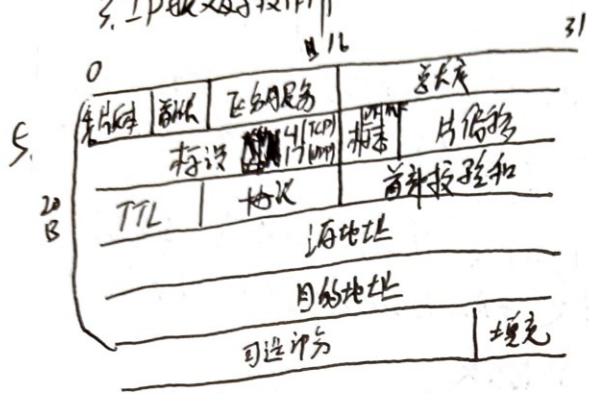
结点距离向量变化后向其邻居发送它们更新后的距离向量, 邻居也更新自己的若变化则算法停止。经过若干次交换更新后所有路由都知道其到自治网络中任意目的网络的最短距离和下一跳地址, 称为收敛。
缺点: 报文大小与网络规模成正比, 大型网络收敛很慢的更新报文, 网络收敛慢
优点: 简单, 开销小, 对消息传递快

3. BGP 边界网关协议 21 考 10 题 TCP 层之 BGP 传输层网络层信息

配置 BGP 时每个 AS 管理员选择至少一个路由器 (往往是 BGP 边界路由器) 作为该 AS 的 "BGP 发言人", 发言人除了运行 BGP 外还要运行 IGP (eg. RIP OSPF)
BGP 交换网络可达性的信息即到达这个网络所要经过的一系列自治系统
在 BGP 可报将所用策略拥塞拥到到达各自治系统相关的较好路由
为 AS 提供: eBGP (从邻居获得信息) iBGP (向邻居通告信息) 层次: AS PATH 属性

4. DMZ作用, 南桥子网

3. IP报文结构作用



- 总入片首四

6

片偏移: ~~IP~~ IPv4: 4 IPv6: 6
 首段长度: 以4B为单位 5x4 ~ 15x4
 总长度: 1B为单位, 最大为 $2^{16}-1 = 65535B$, 实际IP报文总长度不超过MTU 1500B, 数据最多1480B
 标识: 计数器, 产生一个IP数据报标识加1. 当超MTU分片时每个分片都复制标识号
 标志: DF, MF
 片偏移: 除最后一个分片外每个分片长度为8的整数倍, 片偏移单位为8B

7.

协议: TCP: 6 UDP: 17
 首段校验和: 仅校验首部不校验数据部分
 TTL: 数据包在转发前先把TTL-1 置为0则 将数据包并向源点发送 ICMP "超时" 消息, 进入其超时循环

4. 网络拥塞, 网络延迟, 网络性能 24253

拥塞导致数据转发延迟增加, 吞吐量下降, 丢包率上升。可通过调节发送速率避免网络过载。TCP拥塞控制中用了拥塞避免(线性增长)、慢启动(指数增长)、快速重传、快速恢复。
 延迟: 从发送端到接收端的时间, 包含: 传播延迟、传输延迟、排队延迟、处理延迟
 拥塞: 在分组转发网络中存储转发节点资源有限而无法应对大量发送分组导致网络传输性能下降

5. 0.0.0/1:1:1:1 主机号为1111.../0000...

主机全0: 表示网络 0/0表示默认路由(在路由表中)指向任何都不匹配的时间如互联网中的IP
 主机全1: 本网络广播
 0.0.0.0: 网络加入网络得DHCP分配IP
 1.1.1.1: 路由器隔高广播域主节点等网络广播

6. NAT网络地址转换

将专用网络地址转换为公用地址，整个专用网仅用一个经过IP的
缓解IP地址不足，隐藏内部IP，过滤IP地址，流量均衡

7. ARP地址解析协议

原因：链路层看不到IP地址，MAC地址不断改变所以网络层跨网通信
每台主机都有一个ARP高速缓存用以存放本局域网中各主机/路由器
的IP地址到MAC地址的映射表，称ARP表，A主机发送IP报时查ARP
缓存中有B的~~MAC~~ IP-MAC则写入MAC帧；若无则MAC地址FF-FF-FF-
FF-FF-FF (MAC 48位) 来广播ARP请求再发送MAC帧，B收到后向A发送
ARP响应包 (广播发送)，A将其写入ARP缓存再发送MAC帧。

各层作用 ping/traceroute 原理 TCP/UDP TCP流量/拥塞控制 TCP三次握手

1. 各层作用

数据链路层: 差错控制, 相邻结点间传递数据, 流量控制, 可靠交付
网络层: 将分组(IP分组)从源结点传到目的结点, 实现流量控制、拥塞控制、差错控制, 路由和转发, 异构网络互联
传输层: 两个进程之间的通信, 提供端到端的可靠传输, 实现流量控制, 差错控制, 提供面向连接和无连接的协议, 复用和分用
会话层: 管理进程间的会话, 检查点, 断点续传
表示层: 处理交换信息的表示方法的信息, 压缩, 加密, 解密

2. ping

用于测试网络连通性和时延, 发送 ICMP Echo 请求, 目标主机若收到则返回 ICMP Echo Reply 回应, 发送方根据此计算丢包率和往返时延

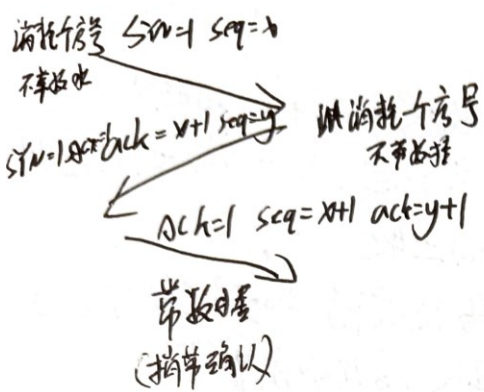
3. traceroute

通过发送逐跳跳端的 IP 报文中的 TTL 使得沿途各路由返回 ~~超时~~ TTL 超时的 ICMP 消息直至返回 ICMP Echo Reply 时端口可达从而生成路由跟踪

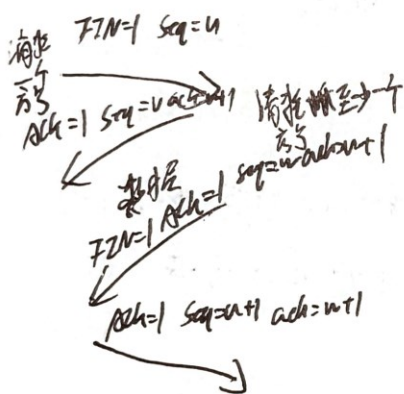
4. TCP vs UDP

- 对首部-数据部分差错检测 (靠 IP 仅对首部作校验和)
- TCP 对差错要求重发 UDP 直接丢弃
- TCP 适合可靠传输要求高的场合 (FTP, HTTP, TELNET)
- UDP 适合实时性要求高的场合 (DNS, SNMP, DHCP, RTSP, RTP)
- TCP 支持拥塞控制 UDP 不支持
- TCP 首部 20B-60B UDP 8B, 首部开销小
- TCP 端口范围 0-65535 UDP 端口范围 0-65535
- TCP 三次握手 UDP 无握手
- TCP 流量控制 UDP 无流量控制
- TCP 拥塞控制 UDP 无拥塞控制
- TCP 可靠传输 UDP 不可靠传输

5. TCP 3次握手 ~~25分~~ ★



6. TCP 4次挥手 ~~25分~~



含义:

- URG 紧急数据优先传输
- ACK 确认号在ACK=1时有效 ack为期望接收的下一个字节
- PSH 不同等级有块延迟的应用上生效
- RST 出错, 释放/拒绝非法数据
- SYN 连接请求/连接恢复
- FIN 发送这个的一方要求释放
- 窗口 rwnd 从此确认号开始接收方可容纳的字节数, 避免发送溢出
- 作为发送 $send$ 发送窗口依据
- 填充: 使TCP首部为4B整数倍

7. TCP 流量控制/滑动窗口

利用接收窗口 rwnd (TCP字段“窗口”)

发送方根据确认报文段中的 rwnd 限制自己的发送窗口的大小
从而将发送的数据量控制在 rwnd 大小之内, 保证A不使B的接收缓存溢出

8. 拥塞控制 vs. 流量控制

拥塞控制是让网络能承载现有的网络负荷, 是全局性的过程, 涉及所有主机
路由以及各种降低网络性能的因素; 流量控制指给点间/发送接收端
之间的速率控制以便接收端来得及接收(不溢出)

拥塞

9. 何谓拥塞

在分组交换网络中，传送分组数目太多时，由于存储转发节点资源有限而造成的网络传输性能下降，表现为分组丢失、分组延迟过大

10. TCP 拥塞控制 ★ 有考 2 年先列

ack/Time out + 慢开始 + 拥塞避免 + 快速重传 + 快速恢复

慢开始阶段发送方每收到一个 ack 就把 $cwnd + 1$ ，当 $cwnd$ 到达 $ssthresh$ 时改用拥塞避免算法即每一个 RTT 把 $cwnd + 1$ ，当网络出现超时时将 $ssthresh$ 改为当前 $cwnd$ 的一半并重新开启慢开始，当 $cwnd$ 到达新 $ssthresh$ 时拥塞避免

3ACK + 快速重传 + 快速恢复 + 拥塞避免

若收到 3 个冗余 ACK 重复确认则快速重传而非等待超时计时器超时并执行快速恢复，把 $ssthresh$ 改为当前 $cwnd$ 的一半并将 $cwnd$ 也改为当前 $cwnd$ 的一半重新开始拥塞避免。

装订线

1. 安全

- 人 < 管理安全: 对人的信息行为的规范约束
- 信息 < 内容安全: 根据信息的内容判断其是否违反特定安全策略
- 数据: 对信息收集、处理、存储、传输、使用、交换、显示、扩散等过程中的保护, 依其级别
- 系统 < 物理安全: 对网络及信息系统物理设备的保护
- 运行安全: 对网络及信息系统的运行过程、运行状态的保护
- 内容安全包括: 内容保护 + 内容审查, 对合法的內容加以保护, 对非法的信息内容实施审查

2. 风险评估

包括风险分析、风险评价

I. 风险分析: 识别风险事件和类型

II. 风险评价: 依风险标准估算风险水平, 确定风险严重性

方法:

- ① 基线评估: 经济有效, 对安全基线比较, 得出基本的安全需求确定方案
- ② 详细评估: 根据全面系统的评估结果确定安全需求及控制方案
- ③ 组合评估: 按实际价值和风险划出不同的评估范围, 分别对较高至低风险作详细评估, 对基线

3. 风险控制

任务: 根据风险评估方案结论建议中的安全措施进行评估, 确定优先级和实施

步骤。

目标: 将安全风险控制在一个可接受的范围内, 最小化其发生最合适的控制

手段:

- ① 风险避免: 避免潜在风险, 降低到可接受水平
- ② 风险控制: 消除风险出现的必要条件, 会弃相应功能
- ③ 风险转移: 其他措施补偿损失 转移风险, 买保险

3. CC

是全面的评估准则, 突出“保持轮廓”概念; 侧重点放在与产品的技术评价
指标评价上。

4. BS7799

用层次化结构化的形式描述了 11 个安全管理要素, 给出了执行目标和
具体控制措施; 明确了安全管理建设的内容, 提供了全面的参考规范。
侧重于安全管理。

1. 邮件服务 25分

组成 邮件客户端, 邮件服务器, SMTP 协议

邮件服务器: 存储用户的 Email

Port 25 SMTP: 邮件服务器之间通信所用协议, 7位 ASCII 码

阶段: 握手 (HELO) 传输 (MAIL FROM, RCPT TO, DATA 等) (QUIT)

Port 110 POP: 邮件访问协议, 客户端向服务器问接取邮件, 格式: 下载并删除/下载并保留

Port 220 IMAP: 能操作服务器上的信息, 可用文件夹组织

2. DHCP 动态主机配置协议 没考过简答

从服务器获取: IP, 子网掩码, 默认网关地址, DNS 服务器名称地址

流程

0.0.0.0 → 255.255.255.255 DHCP discover 发现 全 IP
 DHCP ZP → 255.255.255.255 DHCP offer 提供 全 IP
 0.0.0.0 → 255.255.255.255 DHCP request 请求 IP+1
 DHCP ZP → 255.255.255.255 DHCP ack 确认 IP+1

3. P2P ~~和~~ 仅 13 分

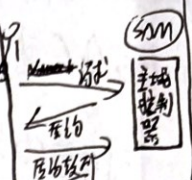
每个节点作为客户端访问其他节点上的资源, 又作为服务器提供资源给其他节点访问

最坏情况: 针对没有的块在集群中选择副本数最少的块, 而均摊每个块得副本数

$$\text{最坏情况时间: } D_{P2P} = \max \left\{ \frac{F}{U_k}, \frac{F}{d_{\min}}, \frac{NF}{U_k + \sum U_i} \right\}$$

↓
最坏情况
服务器速率
→ 可作为限制服务器时间并改进

ALL Win AD CA MAC 身份认证 & 访问控制



1. Win 登陆过程

用户首先通过 Winlogon 窗口输入用户名和密码，向主域控制器发送登录请求，同时计算哈希散列；主域控制器生成一个 8B 的质询发给客户端并从 SAM 中取出哈希散列，用这个哈希散列对质询散列计算得出质询散列；客户端收到 8B 质询也用哈希散列计算出质询散列，发给域控制器；域控制器对比两个质询散列，相同则通过认证。

Netlogon 用于域登陆，与域控制器建立安全通道使用。Winlogon 调用 GINA，Winlogon 调用 GINA，LSA 向 SAM 发认证请求（加密认证）并向网络发送 LSA 消息（加密认证）。

2. Win 访问控制

主要组成：访问令牌；安全描述符

架构核心：安全策略 开始于用户认证 加密和访问控制是主要手段 审计和策略位于内层
Windows 中每个用户和组有一个安全描述符，标识符；每个客体有一个安全描述符，标识符。
包含 ACL 访问控制列表

当用户登录时 LSA 为用户生成访问令牌，用户访问资源时向 SAM 提供访问令牌副本；SAM 根据 DACL 中的 ACE 允许/拒绝用户操作

管理策略可划分为多个 OU，为 OU 制定不同的组策略 GPO，活动目录 AD 面向网络对象，管理网络资源

3. 强制访问控制 MAC

为主体和客体分配不同的安全级别，访问控制时系统对比主体的安全级别与客体的安全级别

是否允许，形式化表示为： $SC(A) = \langle L, C \rangle$ L 为安全级别 C 为安全范围

$SC(a) \geq SC(b)$ 则 a 的级别大于 b S: 主体 O: 客体 $SC(S) \geq SC(O)$ 主体级别不低于客体级别

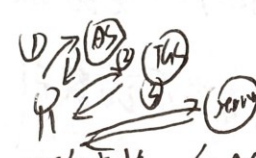
对于 Biba (上读下写) 主体对客体可读不可写 对于 Bell-Lapadula (上读上写) 主体对客体可读可写

特点：安全策略向数据流动方向受策略约束，防止敏感信息扩散，信息单向流动

访问策略三原则：最小特权，最小权限，多级安全

4.1 4. RBAC 基于角色的访问控制 ~~★~~ 老发MAC, 总发错了??

对角色的访问控制 将权限分配给角色而非组/用户, ~~用户和组~~ 组及有相同特质的用户集合, 能授予某些能力和 ~~特~~ 属性的文件的抽象, 用户继承组的权限。优点 避免DAC用户自主授权 敏感信息易扩散的问题 又避免了在规则变化时 DAC 变化调整工作复杂的问题。综合了MAC和DAC特点; 又比MAC适合复杂系统

5. kerberos 认证
- 
- 流程: ① 身份认证服务交互: 和AS完成身份认证, 获取访问TGS的票据
② 票据授予服务交互: 从TGS获得访问应用为票据
③ 客户端与服务端身份认证交互: 发送服务请求, 服务器对客户身份认证

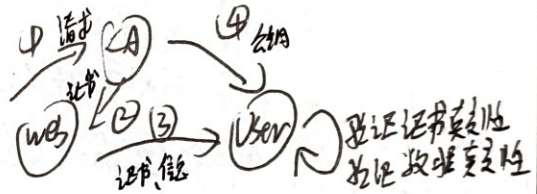
6. 数字证书原理和使用流程 ~~★~~

① 认证方CA 申请证书

② CA 审核请求颁发用CA私钥签名的证书

③ 认证方给验证方提供证书和私钥签名的信息

④ 验证方用CA公钥验证证书是否CA签名, 用证书中的公钥验证证书内容
签名



CA证书内容: 版本号 序列号 主公开钥 签名 有效期 主信息 签名算法标识

PKI核心: 公钥算法, 数字证书

模块: 证书库, 认证机构CA, 密钥备份和恢复, 证书撤销处理, PKI接口

CA间信任信任方式:

有层次: 链之树形模型, 证书链

双向交叉认证: CA互相签发, 用户控制, 折衷CA控制

用户为中心: 用户自主决定信任哪些CA (共 页)

7. 对称密钥的挑战应答认证



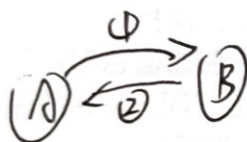
- ①: 发送挑战 N_A
- ②: 发送挑战 N_B
- ③: 发送加密后的挑战 $E_K(N_B)$
- B 验证 $E_K(N_B)$

8. Needham-Schroeder 三方对称密钥认证



- ①: $ID_A || ID_B || N_1$
- ②: $E_{K_A}[K_s || N_1 || ID_B || E_{K_s}[K_s || ID_A]]$
- ③: $E_{K_B}[ID_A || K_s]$ (可用于验证 K_s 是否匹配)
- ④: $E_{K_s}[N_2]$
- ⑤: $E_{K_s}[f(N_2)]$

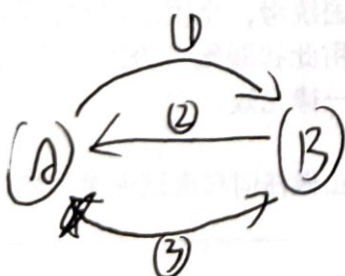
9. 公钥认证



- ①: 发送挑战 N_A
- ②: 发送挑战 N_B
- A 验证 N_B

- ①: 公钥加密 N_A
- ②: 公钥解密 N_A
- A 验证是否一致

10. Needham-Schroeder 双向公钥认证



- ①: 用 B 的公钥加密 N_A
- ②: 用 A 的公钥加密解密 N_A 和 N_B
- ③: 用 B 的公钥加密 N_B

A 验证 N_A
B 验证 N_B

DES RSA HASH 设计原理 数字签名 认证函数

1. 现代密码系统应满足哪些要求

- ① 系统即使达不到理论不可破解，也要在实际上无法破解
- ② 系统的保密性依赖于密钥的保密而非加密体制/算法的保密
- ③ 加密/解密算法适用于所有密钥空间的元素
- ④ 密码系统易于使用

2. 公钥密码体制基本原理

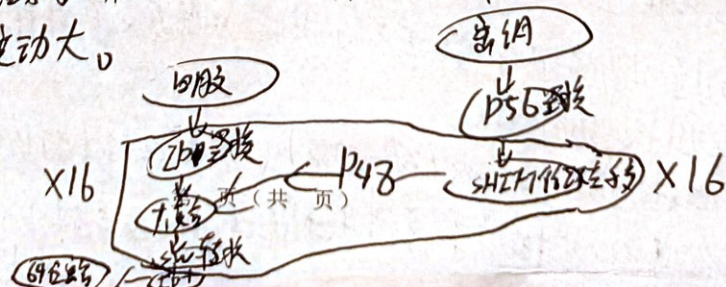
- ① 密钥分为公钥及私钥，公钥公开，私钥保密
- ② 用任一密钥加密用另一个解密为原文，二者配对使用
- ③ 已知其中一个，计算另一个在计算上不可行

3. 对称加密 vs. 非对称加密

对称加密适用于加密大量数据，计算快，密钥短；非对称加密适用于加密少量数据，计算慢，密钥长。非对称加密的公钥可以很长，但要提前分发密钥，大型网络应用密钥管理复杂，无法用于签名。

4. DES

明文64位，密钥64位，其中有效位56位，8位用于奇偶校验，安全性依赖于密钥的保密性。通过5轮迭代使得结果高度非线性，通过拆分为16轮迭代变换提供雪崩效应，使在明文变动时密文变动大。



5. Diffie-Hellman 对的密钥交换协议 ★ 25分

对的密钥; 加密和解密密钥相同, 加密和解密逆运算

DH 数学基础: 离散对数问题

$$A \text{ 选择 } x < P \quad Y = g^x \text{ mod } P$$

$$B \text{ 选择 } x' < P \quad Y' = g^{x'} \text{ mod } P$$

$$A \rightarrow B \quad Y \quad B \rightarrow A \quad Y'$$

$$A \text{ 计算 } (Y')^x \text{ mod } P = k_1 \quad B \text{ 计算 } (Y)^{x'} \text{ mod } P = k_2$$

$$k_1 = k_2 \text{ 由于 } g^{xx'} = g^{x'x} \quad k_1 = k_2 = k \text{ 作为对的密钥}$$

6. RSA ★ 预计计算 (26)

理论基础: 单向陷门函数

数学基础: 欧拉定理、大整数因子分解问题

单向陷门函数 $f(x)$

单向性: 给定 x , 计算 $y = f(x)$ 容易而 $f^{-1}(y)$ 在给定 y 计算 x 困难不可行

陷门性: 存在 0 , 已知 0 时对应给定 y 计算 x 容易

7. 散列函数 ★

目的: 可将任意长度的消息映射为个固定长度的散列值 (消息摘要) 用于消息认证

要求 Hash 函数具有 无碰撞性 单向性。

弱碰撞性: 在明文空间 X 中 给定 $x \in X$, 在计算机上几乎找不到不同于 x 的 $x' \in X$ 使 $h(x) = h(x')$

强碰撞性: 在计算机上 给定 $x \in X$ 几乎无法找到不同于 x 的 x' 使 $h(x) = h(x')$

单向性: 给定 h^{-1} 逆函数求 x 存在在计算上不可行

12. 认证函数, 消息编码

主题三科: 消息加密函数 (公钥、对的)、消息认证码 (对消息摘要、加密函数)、消息编码 (对消息摘要)

消息编码: 基址表示自基址 2 进制数, 在发送后引入冗余, 从大于消息的编码字串中选取用序列, 中如有常用序列而被推出

8. 数字签名

基础：用于验证完整性、真实性、不可否认性

用一套规则和一个参数对数据计算的结果，能据此确认签名者的真实性和完整性。

设计数字签名要满足以下条件：

- ① 伪造数字签名在计算复杂性上不可行
- ② 必使用对发送方说唯一的信息，以防双方伪造否认
- ③ 签名必须基于一个待签名的任意串提取
- ④ 易于生成识别验证

涉及信息：散列函数、发送者公钥、发送者私钥

应用过程：将消息散列，用私钥加密，发送；接收方用一样的散列函数对消息散列，用发送者公钥解密，对比两个散列值验证发送者身份和数据完整性。

装订线

9. 发展过程

古典替换密码 $\rightarrow$ 对称密码 $\rightarrow$ 公开密钥密码

10. 密码体制五要素

E 加密算法 D 解密算法

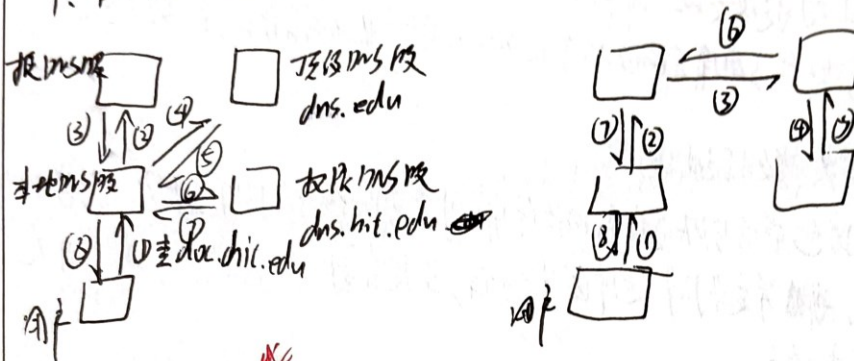
M 明文空间 C 密文空间 K 密钥空间

11. 分组密码 VS. 序列密码

⑧ 分组：明文按固定长度分组 序列：伪随机数发生器产生密钥流对明文逐位进行异或加密
强度源于随机性和不可预测性

Snmp, syn flood, DNS 欺骗, Ping of Death, 缓冲区溢出, ARP 欺骗, Sniffer, BPF, Teardrop

1. DNS 记录



2. DNS 欺骗

由于DNS基于UDP, 无认证机制
监听式之攻击手段

监听受害者的DNS请求信息, 伪造DNS响应发送给受害者, 使其无法访问正确网站, 造成网络环境中要书以ARP欺骗成为中间人。
DNS服务器污染

发送伪造DNS请求并伪造DNS响应使DNS服务器以错误信息更新其内容使其无法提供正确

解析服务, 用户访问会以错误IP口受。

3. Ping of Death / Teardrop

修改IP分片偏移和总长度使ICMP/IP数据包呈现, 发送超长数据包 (2¹⁶-1) 造成缓冲区溢出。
重置使系统重组报文时内存分配错误致使操作系统崩溃。

4. SYN flood

发送大量TCP SYN 连接请求而不回应 ~~ACK~~ SYN ACK 使服务器维护半开连接队列, 耗尽, 造成DOS。

5. Smurf

向广播地址发送伪造源地址为受害主机的ICMP ECHO, 致受害主机收到大量ICMP ECHO REPLY。

6. 网卡 BPF 机制 2533

网卡作为数据链路层，读入数据帧并将在目的地址为自身的广播地址时
对自身的流控模式时接收交由上层协议处理。此时网卡产生硬件中断，操作系统
根据网卡中断程序地址调用驱动程序接收数据交由操作系统处理。

手动设置的
BPF组成：网络分接头、数据过滤器

网卡驱动接收数据包若有BPF进行网络侦听则复制一份给BPF过滤器，若规则
匹配则判定为接收，并复制到缓冲区中暂存，当收集到一定数量时再一并发
给用户进程从而提高效率

7. Sniffer 和嗅探

sniffer嗅探器将网卡设置为混杂模式，拦截所有网络中传输的数据包并交
由上层协议处理。在共享网络环境中可设置混杂模式，而在交换网络中要结
合：

- ① 将捕获程序置于网桥上
- ② 端口嗅探，端口映射
- ③ 交换机与路由器间连接Hub
- ④ ARP欺骗
- ⑤ MAC欺骗

防范：① 检测嗅探器

② 安全拓扑，用VLAN划分出更细的网络划分

③ 地址绑定，路由器IP与MAC绑定，交换机与MAC与端口绑定

④ 会话用Ipsec SSL加密

8. ARP欺骗

OSI链路层 TCP/IP网络层

攻击者伪造IP与MAC的映射用ARP请求/响应的信息使得主机更新ARP缓存，改
使受害者将报文发往错误的MAC地址从而造成窃听；若同时修改通信双
方的ARP缓存则可造成中间人攻击

9. 缓冲区溢出概述

向缓冲区输入超过其长度数据覆盖合法数据, 改变程序执行流程, 导致程序崩溃或执行非法指令, 从而获得系统特权。例如: 代码注入, 写入 shellcode/ROP 攻击: 利用已存在的攻击代码执行非法指令, 传递攻击代码所需的参数。

10. shellcode 作用

可为攻击者开发远程控制端口, 打开 shell 执行系统命令下载病毒或安装木马, 用 C 语言输入汇编代码后编译, 提取二进制利用代码得到 shellcode

11. 栈溢出

堆栈增长方向为高端向内存低端, 反方向为从低到高。当某变量写入数据超过其栈中申请的长度会覆盖相邻栈帧中的变量值, 覆盖 cbp、返回地址等使得改变程序执行流程, 执行更改后地址指向的二进制代码的 shellcode 起始位置。

12. 堆/BSS 溢出

堆或 BSS 增长方向为低到高, 输入超过申请长度数据覆盖相邻堆块的堆控制结构。当程序能发 free() 时在调用 unlink 宏时被篡改的内容被写入任意地址从而改变程序运行流程。

BSS 溢出覆盖函数指针, 在调用该指针时会被转到 shellcode 地址处

13. 防范溢出

① 修改堆栈控制

② 使用安全的语言

③ 对内存变量做严格的长度限制

④ 修复安全漏洞

第 页 (共 页)

以上是我认为 837 最重要的一些考点, 也是我考试当天和考前一天的唯一复习资料。

OrlosZiming 2025.12

更多资料: wangan.online